Phala Network TEE 구현체 분석 - SGX Attestation 시스템

1. SGX Attestation 개요

SGX Attestation은 **원격에서 TEE 환경의 무결성을 검증**하는 핵심 보안 메커니즘으로, Phala Network에서 워커 노드의 신뢰성을 보장하는 데 사용됩니다.

2. 핵심 구성 요소

2.1 의존성 구조

```
# 암호화 및 인증서
├── ring: 암호화 프리미티브 (선택적)
├── webpki: 웹 PKI 인증서 검증
├── x509-cert: X.509 인증서 처리
├── der: DER 인코딩/디코딩
├── asn1_der: ASN.1 DER 처리
├── pem: PEM 형식 처리

# 네트워킹
├── reqwest: HTTP 클라이언트
├── reqwest-env-proxy: 프록시 지원
```

```
├── urlencoding: URL 인코딩


# 직렬화 및 데이터

├── serde: 직렬화 프레임워크

├── serde_json: JSON 직렬화

├── base64: Base64 인코딩

├── hex: 16진수 인코딩

├── chrono: 날짜/시간 처리


# Phala 특화

├── pink-json: Pink JSON 처리

├── pink-types: Pink 타입 정의

└── scale: SCALE 코덱
```

3. Attestation 프로세스

3.1 Quote 생성 과정

```
1. SGX Enclave 초기화

2. Measurement 수집 (MRENCLAVE, MRSIGNER)

3. Report 생성 (로컬 증명)

4. Quote 생성 (원격 증명용)

5. Quote 서명 (Intel 또는 DCAP)
```

3.2 검증 과정

```
1. Quote 수신
2. 서명 검증 (Intel/DCAP 인증서 체인)
3. Measurement 검증 (예상값과 비교)
4. 보안 버전 확인 (SVN)
5. 신뢰성 판단
```

4. 인증서 체인 관리

4.1 Intel 인증서 체인

```
Intel Root CA
├── Intel Intermediate CA
├── PCK Certificate (Platform Certification Key)
└── TCB Info (Trusted Computing Base)
```

4.2 DCAP (Data Center Attestation Primitives)

- **PCK Certificate**: 플랫폼 인증 키
- **TCB Info**: 신뢰 컴퓨팅 베이스 정보
- **QE Identity**: Quoting Enclave 신원
- **Root CA**: 루트 인증 기관

5. 기능 플래그 시스템

5.1 기본 기능

```
[features]
default = ["std", "report", "verify"]
```

5.2 세부 기능

- **std**: 표준 라이브러리 지원
- **report**: Attestation Report 생성
- **verify**: Attestation 검증
- **ring**: Ring 암호화 라이브러리 사용

6. 네트워크 통신

6.1 Intel Attestation Service (IAS)

```
// IAS 통신 예시 (추정)
async fn verify_quote_with_ias(quote: &[u8]) -> Result<AttestationResult> {
let client = reqwest::Client::new();
let response = client
.post("https://api.trustedservices.intel.com/sgx/dev/attestation/v4/report")
.header("Content-Type", "application/json")
.json(&QuoteRequest { quote: base64::encode(quote) })
```

```
.send()
.await?;
parse_ias_response(response).await
}
```

6.2 DCAP 검증

```
// DCAP 검증 예시 (추정)
fn verify_dcap_quote(quote: &[u8], collateral: &Collateral) -> Result<Attestati
let parsed_quote = parse_quote(quote)?;
verify_quote_signature(&parsed_quote, &collateral.pck_cert)?;
verify_tcb_info(&parsed_quote, &collateral.tcb_info)?;
verify_qe_identity(&parsed_quote, &collateral.qe_identity)?;
Ok(AttestationResult::Trusted)
}
```

7. 데이터 구조

7.1 Quote 구조

```
// SGX Quote 구조 (추정)
#[derive(Serialize, Deserialize)]
struct SgxQuote {
```

```
version: u16,
sign_type: u16,
epid_group_id: [u8; 4],
qe_svn: u16,
pce_svn: u16,
xeid: u32,
basename: [u8; 32],
report_body: ReportBody,
signature: Vec<u8>,
}
```

7.2 Report Body

```
// Report Body 구조 (추정)
#[derive(Serialize, Deserialize)]
struct ReportBody {
cpu_svn: [u8; 16],
misc_select: u32,
attributes: [u8; 16],
mr_enclave: [u8; 32], // Enclave Measurement
mr_signer: [u8; 32], // Signer Measurement
isv_prod_id: u16,
isv_svn: u16,
```

```
report_data: [u8; 64], // 사용자 데이터
}
```

8. 보안 고려사항

8.1 인증서 검증

- **체인 검증**: 루트 CA부터 리프까지 전체 체인 검증
- **만료 확인**: 인증서 유효 기간 검증
- **해지 확인**: CRL/OCSP를 통한 해지 상태 확인

8.2 Replay 공격 방지

- **Nonce 사용**: 요청별 고유 값 포함
- **타임스탬프**: 시간 기반 유효성 검증
- **시퀀스 번호**: 순차적 요청 번호 관리

9. 에러 처리

9.1 검증 실패 유형

```
#[derive(Debug, Error)]
enum AttestationError {
#[error("Invalid quote format")]
InvalidQuote,
#[error("Certificate verification failed")]
```

```
CertificateError,

#[error("Measurement mismatch")]

MeasurementMismatch,

#[error("TCB out of date")]

TcbOutOfDate,

#[error("Network error: {0}")]

NetworkError(String),

}
```

9.2 복구 전략

- **재시도**: 네트워크 오류 시 자동 재시도
- **캐싱**: 인증서 및 TCB 정보 캐싱
- **폴백**: 여러 검증 서비스 지원

10. 성능 최적화

10.1 캐싱 전략

- **인증서 캐싱**: 자주 사용되는 인증서 메모리 캐싱
- **TCB 정보 캐싱**: TCB 정보 로컬 저장
- **검증 결과 캐싱**: 동일 Quote 재검증 방지

10.2 비동기 처리

- **병렬 검증**: 여러 Quote 동시 검증
- **스트리밍**: 대용량 데이터 스트리밍 처리

- **타임아웃**: 적절한 타임아웃 설정

이 문서는 SGX Attestation 시스템의 구현 세부사항을 다룹니다. 다음 문서에서는 Pherry 릴레이어 시스템을 분석합니다.